

MARCO INTEGRATIVO GQM + PRAGMATIC

Alineación Objetivos Nacionales → Indicadores → Criterios Calidad

Versión: 2.0

Fecha: Enero 2026

Metodología: GQM (Goal-Question-Metric) + Criterios PRAGMATIC (9 dominios)

Aplicación: Indicadores ADAM Ciberseguridad España

PARTE 1: INTRODUCCIÓN AL MARCO

1.1 ¿Qué es GQM?

Goal-Question-Metric (GQM) es un framework jerárquico para desarrollar métricas alineadas a objetivos estratégicos:

NIVEL 1: OBJETIVO (Goal)
↓ Desagrega en
NIVEL 2: PREGUNTA (Question)
↓ Operacionalizada en
NIVEL 3: MÉTRICA (Metric)

Beneficios:

- Evita métricas "vanidad" (datos bonitos pero inútiles)
- Asegura trazabilidad desde estrategia a operaciones
- Facilita comunicación ejecutiva-técnicos

Ejemplo GQM:

GOAL: Reducir impacto de ciberataques

- Q1: ¿Detectamos amenazas rápidamente?
└ METRIC: MTTD ≤ 15 min (CRITIS)
- Q2: ¿Contenemos incidentes eficientemente?
└ METRIC: MTTC ≤ 4 horas
- Q3: ¿Recuperamos servicios a tiempo?
└ METRIC: MTTR ≤ 24 horas

1.2 ¿Qué es PRAGMATIC?

Pragmatism in Measurement = Capacidad métrica de ser útil en entorno real, no solo teórico.

9 Criterios PRAGMATIC (Glasgow et al., 2013 + adaptaciones ciberseguridad):

Criterio	Definición	Ejemplo
1. Predictivo	¿Métrica predice resultados de seguridad futuros?	MTTD bajo → menores brechas (sí) vs Click rate phishing → incidentes (correlación débil)
2. Relevante	¿Alineada con objetivo estratégico + negocio?	MTTD sí (estrategia: "detección"); Click rate sí (estrategia: "concienciación")
3. Accionable	¿Permite tomar decisiones específicas?	Si MTTD >1h → invertir en SIEM; Si click rate >10% → capacitación extra
4. Genuino	¿Refleja ambiente real (no artificial)?	MTTD genuino (logs reales); Phishing simulada ≠ real
5. Significativo	¿Cambios detectados son operativamente importantes?	MTTD: 15min vs 4h = €3M diferencia impacto (significativo)
6. Preciso	¿Libre de sesgo sistemático?	SIEM timestamps confiables (sí); auto-reporte CISO (potencial sesgo)
7. Oportuno	¿Disponible en tiempo útil para decisión?	MTTD real-time (sí); Auditoría anual (tarde para Q1)
8. Independiente	¿No sujeto a manipulación o efecto Hawthorne?	Falsos positivos SIEM (sí); Simulación phishing conocida (sesgo)
9. Rentable	¿Costo colección datos <80% beneficio?	MTTD (SIEM ya comprado, costo ~€0); Nueva herramienta (€50k)

PARTE 2: ALINEACIÓN GQM A OBJETIVOS NACIONALES

2.1 Objetivo Global España

Enunciado: "Garantizar el uso seguro y fiable del ciberespacio, protegiendo derechos y libertades de ciudadanos y promoviendo progreso socio-económico."

Fuente: Estrategia Nacional Ciberseguridad 2019 + Informe Anual Seguridad Nacional 2024 (DSN)

2.2 Objetivos Específicos + GQM Desagregación

OBJETIVO 1: Garantizar Seguridad y Resiliencia de Activos Estratégicos

OBJETIVO ESTRATÉGICO

- └ PREGUNTA 1.1: ¿Tenemos visibilidad de activos críticos?
 - └ MÉTRICA 1.1.1: % Cobertura Inventario Activos
 - └ MÉTRICA 1.1.2: Activos catalogados vs. detectados
- └ PREGUNTA 1.2: ¿Identificamos vulnerabilidades antes de explotación?
 - └ MÉTRICA 1.2.1: Vulnerabilidades críticas detectadas/año
 - └ MÉTRICA 1.2.2: % Cobertura escaneo vulnerabilidades
 - └ MÉTRICA 1.2.3: Días promedio pre-remediación
- └ PREGUNTA 1.3: ¿Respondemos a incidentes resilientemente?
 - └ MÉTRICA 1.3.1: MTTD (Mean Time To Detect)
 - └ MÉTRICA 1.3.2: MTTC (Mean Time To Contain)
 - └ MÉTRICA 1.3.3: MTTR (Mean Time To Recover)
 - └ MÉTRICA 1.3.4: RTO/RPO cumplido (%)

Mapeo a Dominios NIST CSF 2.0:

- Preguntas 1.1-1.2 → IDENTIFICAR (ID)
- Pregunta 1.3 → RESPONDER (RS) + RECUPERAR (RC)

OBJETIVO 2: Reforzar Capacidades de Investigación y Persecución

OBJETIVO ESTRATÉGICO

- └ PREGUNTA 2.1: ¿Detectamos cibercriminalidad en tiempo real?
 - └ MÉTRICA 2.1.1: MTTD (cibercriminalidad específica)
 - └ MÉTRICA 2.1.2: % Casos investigados vs. detectados
- └ PREGUNTA 2.2: ¿Preservamos evidencia forense?
 - └ MÉTRICA 2.2.1: % Incidentes con cadena custodia completa
 - └ MÉTRICA 2.2.2: Valor probatorio sentencias (%)
- └ PREGUNTA 2.3: ¿Coordinamos respuesta entre agencias?
 - └ MÉTRICA 2.3.1: Tiempo notificación a autoridades
 - └ MÉTRICA 2.3.2: % Casos derivados CNI/Polici a/Fiscal a

Mapeo a Dominios NIST CSF:

- Preguntas 2.1-2.3 → DETECTAR (DE) + RESPONDER (RS)

OBJETIVO 3: Impulsar Ciberseguridad Ciudadanos y Empresas

OBJETIVO ESTRATÉGICO

- └ PREGUNTA 3.1: ¿Están conscientes de riesgos?
 - └ MÉTRICA 3.1.1: % Ciudadanía concienciada (encuesta anual)
 - └ MÉTRICA 3.1.2: % Empleados capacitados
 - └ MÉTRICA 3.1.3: Click rate phishing simulada
- └ PREGUNTA 3.2: ¿Implementan controles básicos?
 - └ MÉTRICA 3.2.1: % Organizaciones con MFA
 - └ MÉTRICA 3.2.2: % Sistemas parchados (críticos)
 - └ MÉTRICA 3.2.3: % Backups aire-gapped
- └ PREGUNTA 3.3: ¿Reducen impacto incidentes?
 - └ MÉTRICA 3.3.1: Costo promedio incidente (€)
 - └ MÉTRICA 3.3.2: Tasa recuperación post-incidente (%)

Mapeo a Dominios NIST CSF:

- Preguntas 3.1 → PROTEGER (PR - capacitación)
- Preguntas 3.2-3.3 → PROTEGER (PR) + RECUPERAR (RC)

OBJETIVO 4: Potenciar Industria Española de Ciberseguridad

OBJETIVO ESTRATÉGICO

- └ PREGUNTA 4.1: ¿Retenemos talento en ciberseguridad?
 - └ MÉTRICA 4.1.1: Número profesionales ciberseguridad España
 - └ MÉTRICA 4.1.2: Salarios promedio sector (vs. UE)
 - └ MÉTRICA 4.1.3: Rotación anual CISO (%)
- └ PREGUNTA 4.2: ¿Crece capacidad industria?
 - └ MÉTRICA 4.2.1: Empresas especializadas (incremento YoY)
 - └ MÉTRICA 4.2.2: Ingresos sector (€ acumulado)
 - └ MÉTRICA 4.2.3: Exportaciones ciberseguridad
- └ PREGUNTA 4.3: ¿Lideramos innovación?
 - └ MÉTRICA 4.3.1: Patentes ciberseguridad (España/año)
 - └ MÉTRICA 4.3.2: Startups ciberseguridad financiadas
 - └ MÉTRICA 4.3.3: Posición España en Global Cybersecurity Index

Mapeo a Dominios NIST CSF:

- Preguntas 4.1-4.3 → GOBERNAR (GV - capacidad)

PARTE 3: EVALUACIÓN PRAGMATIC POR MÉTRICA

3.1 Matriz PRAGMATIC (Resumen)

Escala PRAGMATIC: 9/9 EXCELENTE | 7-8/9 BUENO | 5-6/9 ACEPTABLE | <5/9 DÉBIL

Métrica	P	R	A	G	S	Pr	O	I	Rn	Σ	Calificación
MTTD	✓	✓	✓	✓	✓	✓	✓	✓	✓	9	EXCELENTE
MTTC	✓	✓	✓	✓	✓	✓	✓	✓	✓	9	EXCELENTE
% Cobertura Inv.	✓	✓	✓	✓	✓	✓	✓	✓	✓	9	EXCELENTE
Click Rate Phishing	~	✓	✓	~	✓	✓	✓	~	✓	7	BUENO
CISO Reporta CEO	~	✓	✓	✓	~	✓	✓	✓	~	7	BUENO
IGM (Índice Madurez)	✓	✓	✓	~	✓	~	✓	~	✓	7	BUENO
% Cumpl. NIS2	✓	✓	✓	✓	✓	~	✓	~	~	6	ACEPTABLE
Talentos Retenidos (#)	~	✓	~	✓	~	✓	✓	✓	~	5	ACEPTABLE
Ingresos Sector (€)	~	✓	~	✓	~	✓	✓	✓	~	5	ACEPTABLE
Patentes Ciberseg. (#)	~	~	~	✓	~	✓	~	✓	~	3	DÉBIL

Leyenda: ✓=Cumple, ~=Parcial, Blanco=No cumple

PARTE 4: RECOMENDACIONES DE IMPLEMENTACIÓN

4.1 Selección de Indicadores Clave (Top 10 PRAGMATIC)

Priorizar métricas con puntuación PRAGMATIC $\geq 7/9$:

Prioritarios (Implementación Inmediata):

1. MTTD ≤ 15 min (CRITIS) / ≤ 1 h (Empresa)
2. MTTC ≤ 4 horas
3. % Cobertura Inventario $\geq 90\%$
4. % Vulnerabilidades Críticas Remediadas 30d $\geq 80\%$
5. MTTR ≤ 24 horas (crítico)

Secundarios (Próximos 6 meses):

6. Click Rate Phishing $< 5\%$
7. IGM ≥ 3.0 (Nivel Madurez 2+)
8. CISO Reporta CEO: Sí/No
9. % Cumplimiento NIS2 $\geq 90\%$
10. RTO/RPO ≤ 72 horas (CRITIS)

4.2 Evitar Métricas Débiles PRAGMATIC

No Recomendar (puntuación $< 5/9$):

- Patentes ciberseguridad/año (débil predictividad)
- Ingresos totales sector (correlación negativa con seguridad)
- Rotación CISO (lag de 2-3 años hasta impacto)

PARTE 5: TRAZABILIDAD COMPLETA (Ejemplo)

Escenario: Mejora de Detección de Amenazas

OBJETIVO NACIONAL

- └ "Fortalecer capacidades de prevención, detección y respuesta"
 - └ PREGUNTA GQM (Nivel 2)
 - └ "¿Detectamos amenazas rápidamente?"
 - └ MÉTRICA OPERACIONAL (Nivel 3)
 - └ "MTTD ≤ 15 minutos (CRITIS)"
 - └ EVALUACIÓN PRAGMATIC (9 criterios)
 - └ Predictivo: Sí (MTTD bajo $\rightarrow$ impacto bajo, evidenciado)
 - └ Relevante: Sí (alineado a objetivo)
 - └ Accionable: Sí (si $>15\text{min}$ $\rightarrow$ revisar SIEM)
 - └ Genuino: Sí (datos automatizados SIEM, sin sesgo humano)
 - └ Significativo: Sí (15min vs 4h = €3M diferencia)
 - └ Preciso: Sí (logs timestamp confiables)
 - └ Oportuno: Sí (real-time disponible)
 - └ Independiente: Sí (métrica automatizada)
 - └ Rentable: Sí (costo marginal $\sim \text{€}0$)
 - └ DECISIÓN: Implementar + Monitorear MTTD
 - └ TARGET Q1 2026: MTTD $<15\text{min}$ alcanzado
 - └ VALIDACIÓN: Reducción incidentes críticos 40% YoY

PARTE 6: CONCLUSIONES

Valor del Marco GQM + PRAGMATIC

1. Trazabilidad: Cada métrica ligada a objetivo nacional
2. Calidad: Solo métricas que cumplen 9 criterios pragmatismo
3. Acción: No hay "métricas bonitas pero inútiles"
4. Comunicación: Ejecutivos entienden OBJETIVO; técnicos entienden MÉTRICA

Próximos Pasos

5. Implementar Top 10 métricas PRAGMATIC (Documento 2: Matriz)
6. Establecer targets por métrica (Documento 4: Excel)
7. Monitoreo trimestral (Documento 5: Reporte Ejecutivo)
8. Validación con auditoría externa anual

Fin del Marco Integrativo GQM + PRAGMATIC

Referencia: Glasgow et al. 2013; PRECIS-2 Tool; ENISA National Capabilities Assessment 2020; DSN Estrategia Ciberseguridad 2019